

GOVERNANCE, RISK AND COMPLIANCE POLICY REPORT

Prepared for
SECURYTH CONSULTING

Version 1.0 | February 2026

Table of Contents

Executive Summary

Policy Index

- Policy 1: Information Security Policy
- Policy 2: Information Classification Policy
- Policy 3: Identity and Access Management Policy
- Policy 4: Privileged Account Policy
- Policy 5: Artificial Intelligence (AI) Usage and Governance Policy
- Policy 6: Incident Management Policy
- Policy 7: Clear Desk and Clear Screen Policy
- Policy 8: Remote Work Policy
- Policy 9: Mobile Device Policy
- Policy 10: Corporate Travel Security Policy

Additional Sections

- Recommendations
- Conclusion

Note: Right-click this table of contents in Word and select 'Update Field' to refresh page numbers.

Executive Summary

Governance, Risk, and Compliance (GRC) is a strategic framework that integrates organizational oversight, risk management, and regulatory adherence to ensure effective and ethical operations. It enables institutions to establish clear accountability structures, align business objectives with legal and regulatory requirements, and systematically identify and mitigate risks. By formalizing policies, controls, and monitoring mechanisms, GRC enhances transparency, supports informed decision-making, and strengthens internal control environments.

Policies are fundamental to the effective functioning of Securyth Consulting as a financial consulting firm because they establish formal structures that govern operations, ensure regulatory compliance, and manage organizational risk. In a highly regulated and trust-dependent industry, documented policies standardize procedures, define roles and responsibilities, and provide clear guidance for handling sensitive financial information, thereby reducing errors, legal exposure, and operational inconsistencies.

They also demonstrate due diligence to regulators and clients, strengthen internal controls, and promote accountability and ethical conduct among employees. Consequently, well-designed policies not only safeguard client data and institutional reputation but also support informed decision-making and sustainable organizational performance.

In this sprint, ten policies were developed. Seven were provided and the remaining three Remote Work Policy, Mobile Device Policy, and Corporate Travel Security Policy were developed based on industry requirements. The selection of these policies was driven by the specific operational and risk environment of a Professional services firm.

Because consultants frequently work outside traditional office settings whether from home, client sites, or during business travel the organization faces increased exposure to data breaches, device loss, insecure networks, and unauthorized access to sensitive financial information. A Remote Work Policy ensures that offsite work is conducted securely and in compliance with regulatory expectations, while a Mobile Device Policy governs the protection, configuration, and acceptable use of portable devices that store or access confidential client data. The Corporate Travel Security Policy addresses physical, digital, and situational risks encountered during domestic and international travel, safeguarding both personnel and information assets.

Together, these policies were prioritized because they directly mitigate the most significant operational risks associated with the firm's consulting model, mobility requirements, and obligation to maintain strict confidentiality and regulatory compliance.

Policy Approval Communication

The policies were communicated to employees via email. Below is an example of a policy approval notification:

From	Chief Information Officer
To	Chief Information Security Officer
Cc	Information Security Manager
Subject	Mobile Device Policy Approval

I have reviewed the Mobile Device Policy for Securyth Consulting and hereby approve it for implementation across the organisation.

Approved by: Chief Information Officer

Date: 20 February 2026

We also created an account on Wizer where we uploaded all the policies for the employees to view them

POLICY 1: INFORMATION SECURITY POLICY

Policy ID	SCT-ISP-001
Version	1.0
Effective Date	18 February 2026
Author (Role)	Information Security Manager
Policy Owner	Chief Information Security Officer (CISO)
Reviewer	Risk & Compliance Director
Approver	Chief Executive Officer (CEO)
Current Review Date	18 February 2026
Next Review Date	18 February 2027
Domain	ISO 27002:2022 - 5 Organizational Controls
Sub-domain	5.1 Policies for Information Security

1. Purpose

This policy establishes Securyth Consulting's framework for safeguarding clients, financial, operational, and personal information in alignment with ISO/IEC 27002:2022 and applicable regulatory obligations. It establishes a high-level framework for protecting the confidentiality, integrity, and availability of Securyth Consulting information assets.

2. Scope

This policy applies to:

- All Securyth Consulting employees, contractors, and third parties
- All information assets regardless of format
- All systems, cloud platforms, and global offices handling organizational information

3. Policy Statements

- The organization shall define a high-level information security policy that sets the overarching approach to managing information security.
- All information security policies must be formally approved by top management before publication.
- The policy must align with the organization's broader business strategy and operational requirements.
- The policy shall provide a clear definition of information security and its importance to the business.
- Information security objectives must be clearly defined or a framework for setting them established within the policy.
- The policy shall include the core principles that guide all information security activities across the organization.

- A formal commitment to satisfy all applicable security requirements must be explicitly stated.
- The policy must include a commitment to the continual improvement of the Information Security Management System (ISMS).
- Responsibilities for information security management shall be assigned to clearly defined roles.
- Procedures for handling policy exemptions and exceptions must be documented and followed.
- The policy shall be published and made accessible to all relevant personnel and interested parties.
- Relevant personnel must acknowledge the policy to demonstrate their understanding and commitment.
- Management shall conduct a review of the policy at planned intervals to ensure its continuing suitability.
- A policy review must be triggered immediately if significant changes occur in the business or threat environment.
- Topic-specific policies shall be developed to provide more detailed rules for specific security areas (e.g., access control).

4. Securyth Consulting Requirement Alignment

This policy supports Securyth engagement expectations by ensuring governance structure is defined; establishing accountability, demonstrating ISO 27002:2022 alignment, supporting audit-readiness and enforcing documented review cycles.

5. Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer (CISO)	Overall security governance
Information Security Manager	ISMS implementation and monitoring
IAM Specialist	Access control and quarterly access reviews
Security Engineer	Technical security control implementation
Risk & Compliance Director	Regulatory alignment and audits
All Employees	Compliance and incident reporting

6. Compliance & Monitoring

This policy shall be reviewed annually or upon major regulatory changes, significant security incidents, and organisational restructuring.

7. Enforcement

Failure to comply may result in disciplinary action, termination of contract, and legal action where applicable.

8. Evidence of Approval

Approved via Executive Email Confirmation dated 17 February 2026 from CEO authorizing implementation effective 18 February 2026.

POLICY 2: INFORMATION CLASSIFICATION POLICY

Policy ID	SCT-ICP-002
Version	1.0
Effective Date	18 February 2026
Author (Role)	IAM Specialist
Policy Owner	Chief Information Security Officer (CISO)
Reviewer	Information Security Manager
Approver	Chief Operating Officer (COO)
Current Review Date	18 February 2026
Next Review Date	18 February 2027
Domain	ISO 27002:2022 - 5 Organizational Controls
Sub-domain	5.12, 5.13 & 5.14 Classification and Labelling

1. Purpose

The purpose of this policy is to ensure that information is classified according to its sensitivity, value, legal requirements, and criticality to Securyth Consulting, and that appropriate protection measures are applied.

2. Scope

This policy applies to:

- All information assets, regardless of format (electronic, physical, verbal)
- All systems, applications, devices, and storage media that store or process information
- All employees and third parties handling organizational information

3. Classification Levels

Level	Description
Public	Approved for public release
Internal	For Securyth Consulting internal use only
Confidential	Sensitive client or business data
Restricted	Highly sensitive strategic or regulated information

4. Roles and Responsibilities

Role	Responsibility
Information Owner	Determines classification and reviews classification annually

IAM Specialist	Ensures access rights align with classification
Security Engineer	Implements encryption and DLP controls
Employees	Handles information according to classification

5. Policy Statements

- Information must be classified according to its security needs based on confidentiality, integrity, and availability.
- The classification scheme shall account for the potential negative business impact of unauthorized disclosure or loss.
- Each information asset shall have a designated owner accountable for its classification.
- Information Owners must identify the protection needs of their assets in accordance with their importance.
- Personnel must label information in accordance with its assigned classification level.
- Digital information shall utilize metadata to identify and control the information based on its sensitivity.
- Procedures shall specify how to handle cases where physical or technical labelling is not possible.
- Sensitive conversations must begin with a disclaimer regarding the classification level of the information being discussed.
- The organization shall establish handling procedures for each classification level (e.g., encryption for restricted data).
- Information sharing agreements with third parties must include procedures to interpret classification levels.
- All system outputs (e.g., printed reports) must carry an appropriate classification label.
- Information shall be re-evaluated periodically to determine if its classification remains appropriate as it ages.
- Over-classification must be avoided to prevent unnecessary costs and operational friction.
- Secure disposal procedures must be implemented for all information assets in accordance with their classification.

6. Compliance & Monitoring

This policy shall be reviewed annually or upon major regulatory changes, significant security incidents and organisational restructuring.

Monitoring Activities:

- Annual ISMS review - CISO
- Quarterly access review - IAM Specialist
- Annual regulatory compliance audit - Risk Director
- Quarterly classification audit - Information Security Manager

POLICY 3: IDENTITY AND ACCESS MANAGEMENT POLICY

Policy ID	SCT-IAM-003
Version	1.0
Effective Date	17 February 2026
Author (Role)	Information Security Manager
Policy Owner	Chief Information Security Officer (CISO)
Reviewer	IAM Specialist
Approver	Chief Information Officer
Current Review Date	17 February 2026
Next Review Date	17 February 2027
Domain	ISO 27002:2022 - 5 Organizational Controls
Sub-domain	5.15 Access control, 5.16 Identity management, 5.18 Access rights
Control Type	Preventive

1. Purpose

Securyth Consulting global systems are accessed by thousands of users daily to deliver services involving client data. Uncontrolled access could lead to data breaches, regulatory violations, or internal misuse. This policy ensures that identities are uniquely managed, access is granted on a strict need-to-know and least-privilege basis, and access rights are regularly reviewed and revoked when no longer required. It protects client confidentiality and system integrity while enabling secure collaboration across service lines and geographies.

2. Scope

This policy applies to all Securyth member firms globally. It covers every user identity, user account, service account, system account, application, database, network resource, cloud platform, physical access control system, and any other resource that stores, processes, or transmits Securyth or client information.

The policy extends to all personnel categories, including partners, full-time employees, contractors, temporary staff, interns, secondees, and any third-party suppliers or service providers who are granted access to Securyth systems. It applies in all locations and work arrangements, including Securyth offices, client premises, home offices, hotels during travel, and any mobile or remote working scenario.

3. Definitions

- Identity: Unique representation of a person or system.
- Authentication: Verification of a claimed identity.
- Authorisation: Permission to perform specific actions on resources.
- Least Privilege: Granting only the minimum access necessary.

- Need-to-Know: Access limited to what is required for a specific role or task.
- Multi-Factor Authentication: Use of two or more verification factors.
- Access Review: Periodic verification that access rights remain appropriate.

4. Policy Statements

- Every individual and service account shall have a unique identity linked to their Securyth record.
- Shared or generic accounts are prohibited except in rare approved cases with compensating controls.
- Access requests must be submitted through the formal IAM portal and approved by both the line manager and information owner.
- Multi-factor authentication is mandatory for all accounts, with higher assurance required for sensitive systems.
- Access rights shall be reviewed at least quarterly for high-risk systems and every six months for others.
- Access shall be revoked within 24 hours of an individual leaving Securyth.
- Role changes shall trigger immediate review and adjustment of access rights.
- The need-to-know and least-privilege principles shall govern all access decisions.
- Segregation of duties shall be enforced for high-risk processes.
- All access events shall be logged centrally and retained for at least 12 months.
- Emergency access procedures shall include automatic notification to the CISO and post-use review within 48 hours.
- Third-party access shall be time-limited, monitored, and reviewed quarterly.
- Mobile and remote access shall require device compliance checks.
- Password and authentication standards shall meet or exceed industry best practices.
- Annual training on secure access practices is mandatory.
- Suspected credential compromise shall trigger immediate account suspension.
- Access provisioning shall be integrated with HR onboarding and offboarding systems.
- Automated tools shall be used to detect and alert on excessive or anomalous access.

5. Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer	Overall policy owner; final escalation point; approves exceptions.
IAM Specialist	Day-to-day management of IAM systems; leads access reviews; maintains tools.
Information Owner	Approves access to their data or systems; participates in reviews.
Line Manager	Initiates and approves access requests for their team members.
All Personnel	Use access only for authorised purposes; protect credentials; report issues.
Data Protection Officer	Provides input on regulatory aspects of access decisions.

6. Monitoring and Compliance

Compliance with this policy is monitored through:

- Quarterly access rights reviews documented in the central IAM system, with completion rates reported to the CISO.
- Automated dashboards showing overdue reviews, exception counts, and MFA adoption rates.
- Monthly reports on access-related security incidents.
- Inclusion of identity and access controls in the annual internal audit programme and external regulatory audits.
- Annual user acknowledgement of the policy during mandatory security awareness training.

7. ISO 27002:2022 Alignment

This policy fully implements the following controls from ISO/IEC 27002:2022:

Control 5.15 - Access Control: Access to information and other associated assets shall be defined and controlled in accordance with the access control policy. The policy satisfies this through formal request and approval processes, least privilege, and technical enforcement.

Control 5.16 - Identity Management: The organisation shall implement processes to manage the full lifecycle of identities. The policy covers unique identities, provisioning, review, and de-provisioning with integration to HR systems.

Control 5.18 - Access Rights: Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed in accordance with the organisation's topic-specific policy on access control.

8. Policy Sanctions

Any breach of this policy will be investigated promptly and fairly by the Information Security team, working together with Human Resources and the relevant business leadership. Consequences will be proportionate to the seriousness of the violation and its potential impact on clients or regulatory compliance.

POLICY 4: PRIVILEGED ACCOUNT POLICY

Policy ID	SCT-PAP-004
Version	1.0
Date of Issue	17 February 2026
Last Review Date	17 February 2026
Next Review Date	17 February 2027
Author	Identity and Access Management (IAM) Specialist
Policy Owner	Chief Information Security Officer (CISO)
Reviewer	Information Security Manager
Approver	Chief Information Security Officer (CISO)
Review Frequency	Annually or upon significant organizational/technical change
Classification	Internal Use - Restricted
ISO/IEC 27002:2022 Domain	Protection - Identity and Access Management
ISO/IEC 27002:2022 Control	8.2 Privileged Access Rights

1. Purpose

To establish a framework for the secure management, allocation, use, and monitoring of privileged accounts across Securyth Consulting's global professional services organization, ensuring protection of client confidential information, firm intellectual property, and critical business systems.

2. Scope

This policy applies to:

- All Securyth Consulting personnel with privileged access rights
- All systems, applications, databases, networks, and cloud environments processing Securyth Consulting or client information
- Third-party suppliers, contractors, and managed service providers requiring privileged access
- All geographic regions and service lines (Audit & Assurance, Consulting, Financial Advisory, Risk Advisory, Tax & Legal)

3. Definitions

- **Account (User ID or Username):** A unique string of characters assigned to a user identifying that person to a computer system or network.
- **Break Glass (Emergency Access):** Pre-staged emergency accounts for catastrophic system failures when standard PAM mechanisms are unavailable.
- **Just-in-Time (JIT) Elevation:** Temporary privileged access granted for specific time-bound administrative tasks rather than standing permanent access.

- **Least Privilege:** The principle that administrators are granted only the minimum rights required to perform specific tasks.
- **Multi-Factor Authentication (MFA):** Authentication requiring two or more verification factors: something you know, something you have, or something you are.
- **Privileged Access Management (PAM):** Centralized system for managing, securing, and monitoring privileged accounts and credentials.
- **Privileged Account:** An account with system privileges beyond standard user access, including administrator, root, service, and emergency accounts.
- **Privileged User:** Any Securyth Consulting employee, contractor, or third party granted privileged account access.
- **Service Account:** Non-human account used by applications or automated processes requiring privileged access.
- **System Administrator:** Employee responsible for managing Securyth Consulting multi-user computing environments.
- **Third Party:** Any non-employee contractually bound to provide services to Securyth Consulting.

4. Policy Statement

Securyth Consulting shall restrict and tightly control privileged access rights to ensure only authorized users, software components, and services are provided with privileged access, in accordance with ISO/IEC 27002:2022 Control 8.2 and industry best practices.

5. Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer (CISO)	Serves as policy owner with ultimate accountability; approves exceptions and high-risk privileged access grants; reviews quarterly privileged access reports.
IAM Specialist	Handles technical implementation of privileged access controls; administers PAM solution; conducts access certification campaigns.
Information Security Manager	Reviews policy annually and upon significant changes; monitors compliance; coordinates incident response.
Security Engineer	Configures privileged access systems; integrates PAM tools; implements secure authentication mechanisms.
Data and System Owners	Approve privileged access to their specific assets; attest quarterly to privileged user lists; request removal of unnecessary access.
Privileged Users	Comply with all policy requirements; use privileged accounts only for authorized administrative tasks; report credential compromise immediately.
Internal Auditor	Provides independent assurance annually through formal audit engagement; reports findings to Audit Committee.

6. Policy Requirements

6.1 Authentication and Access Control

Purpose: Ensure only authorized users access privileged accounts with the strongest authentication.

- Multi-factor authentication is mandatory for all privileged access.
- Step-up authentication required for unusual locations or hours, sensitive client data access, and high-impact operations.
- Privileged accounts: 16-127 characters, random, rotated every 24 hours.
- Elevated user accounts: 12 characters minimum, changed every 90 days. No null passwords permitted.
- PAM system automatically enforces password complexity at creation.

6.2 Privileged Account Management

Purpose: Centralize and automate privileged account lifecycle to reduce risk.

- Central PAM system for all privileged accounts with full audit trails.
- Directory integration with Active Directory for authentication.
- Strong authentication integration including RSA SecurID, Duo, FIDO2.
- Emergency access (break glass): Dual-control activation, pre-staged for catastrophic failures, full session recording.
- Vault encryption: AES-256 for all stored credentials.
- Account inventory: Automated discovery, updated monthly.
- Inactive accounts: Suspended after 45 days, removed after 90 days.

6.3 Privileged Account Logging and Audit

Purpose: Maintain comprehensive visibility and accountability for all privileged activities.

- All privileged commands traceable to individuals.
- Creation, deletion, and permission changes securely logged.
- Full session recording for Tier 0 and Tier 1 accounts.
- Quarterly automated reports and anomaly detection.
- SIEM integration: All logs aggregated for correlation with security events.
- Tamper protection: Cryptographic hashing, append-only storage.
- Annual Internal Audit review.

6.4 Third-Party and Outsourced Privileged Access

Purpose: Manage elevated risk from non-employee privileged access.

- Default 30-day expiration for all third-party privileged accounts.
- All third-party sessions recorded with SOC real-time monitoring.
- Security clauses, audit rights, and breach notification required in all agreements.
- System owner plus Information Security approval required.
- Just-in-time elevation preferred; recertification required for extensions.

6.5 Privileged Account Approval

Purpose: Ensure strict governance and segregation of duties for privileged access grants.

- Dual approval: System/Data Owner plus Information Security for all privileged accounts.
- Just-in-Time elevation: Time-bound access preferred over standing privileges.
- Role-based access: Granular permissions aligned to specific job functions.
- Authorization workflow: ServiceNow GRC with full audit trail.

- Emergency access: CISO approval required, post-event review within 24 hours.

6.6 Privileged Access Lifecycle

Purpose: Manage privileged accounts from creation through removal.

- Provisioning: Complete authorization workflow before first access.
- Quarterly certification: Data/System Owners attest necessity of each privileged user.
- Modification: Role changes trigger automatic review; re-authorization required.
- Suspension: Inactive accounts suspended after 45 days.
- Revocation: Immediate removal upon termination or suspected compromise.
- De-provisioning: Verification no orphaned accounts remain; knowledge transfer documented.

POLICY 5: ARTIFICIAL INTELLIGENCE (AI) USAGE AND GOVERNANCE POLICY

Document ID	SCT-GP-005
Version	1.0
Issue Date	17 February 2026
Next Review Date	17 February 2027
Author	Information Security Manager
Policy Owner	Chief Information Security Officer
Reviewer	Head of Technology Risk
Approver	Chief Information Officer
Classification	Securyth Internal - Confidential
Domain	ISO 27002:2022 - Organizational Controls (Clause 5)
Sub-domain / Controls	5.10 Acceptable use, 5.12 Classification of information, 5.23 Cloud services
Control Type	Preventive / Detective

1. Purpose

Securyth delivers professional services that involve handling sensitive client information, proprietary methodologies, and confidential business insights. The increasing adoption of Artificial Intelligence (AI) tools introduces significant opportunities for efficiency and innovation, but also introduces risks related to data exposure, intellectual property leakage, inaccurate outputs, regulatory non-compliance, and ethical concerns.

This policy establishes governance requirements for the responsible, secure, and ethical use of Artificial Intelligence technologies across Securyth. It ensures that AI tools are used in a controlled manner that protects client confidentiality, maintains professional integrity, and complies with regulatory and contractual obligations while enabling innovation and productivity.

2. Scope

This policy applies to all Securyth personnel globally, including partners, employees, contractors, interns, temporary staff, and third-party service providers who use or interact with Artificial Intelligence systems on behalf of the organisation.

It covers:

- Public AI platforms (e.g., generative AI tools)
- Internally developed AI solutions
- Third-party AI services integrated into business systems
- AI used for analytics, automation, document generation, decision support, or software development
- AI tools accessed via corporate devices, personal devices used for work, or cloud platforms

The policy applies across all working environments including offices, remote locations, client sites, and travel scenarios.

3. Definitions

- **Artificial Intelligence (AI):** Systems capable of performing tasks that normally require human intelligence, including machine learning, natural language processing, and predictive analytics.
- **Generative AI:** AI systems that create new content such as text, images, or code.
- **Sensitive Information:** Confidential, restricted, or client data that requires protection under Securyth policies.
- **AI Output:** Any content generated or produced by an AI system.
- **Human Oversight:** Review and validation performed by a qualified individual before relying on AI output.

4. Policy Statements

- AI tools shall only be used for legitimate business purposes aligned with Securyth's professional services and ethical standards.
- Confidential, restricted, or client information shall not be entered into public or unapproved AI systems.
- All AI-generated outputs used in client deliverables or business decisions must undergo human review and validation before use.
- AI tools must be approved by the Information Security and Technology Risk functions before integration into corporate systems or workflows.
- Personnel must not rely solely on AI outputs for professional judgement, regulatory advice, or decision-making without appropriate verification.
- AI usage must comply with applicable data protection laws, contractual obligations, intellectual property rights, and professional standards.
- Automated decision-making systems that could impact clients, employees, or business outcomes must undergo risk assessment and governance approval.
- AI systems shall be monitored to detect inappropriate usage, data leakage risks, or security vulnerabilities.
- Personnel shall receive training on responsible AI usage, limitations, and associated risks.
- The organisation reserves the right to restrict, monitor, or disable AI tools that present unacceptable risk.

5. Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer	Overall policy owner; ensures AI risks are incorporated into enterprise security governance; approves exceptions.
Head of Technology Risk	Oversees AI risk assessment processes; ensures alignment with regulatory and ethical requirements.
IT Department	Implements technical controls, monitoring, and approved AI integrations.
Information Security Team	Provides guidance on secure AI usage; monitors compliance and investigates incidents.

Business Unit Leaders	Ensure AI tools used within their teams comply with policy requirements.
All Personnel	Use AI responsibly; protect sensitive information; validate outputs; report concerns or incidents.

6. Monitoring and Compliance

Compliance with this policy is monitored through:

- Periodic audits of AI tool usage across systems and networks.
- Monitoring of data uploads to detect potential exposure of confidential information.
- Risk assessments conducted before approval of new AI tools or integrations.
- Inclusion of AI governance controls in internal audit programmes.
- Annual acknowledgement of responsible AI usage requirements during security awareness training.
- Violations or misuse of AI technologies may result in disciplinary action, contractual consequences, or legal action depending on severity.

7. ISO 27002:2022 Alignment

This policy supports implementation of the following controls from ISO/IEC 27002:2022:

- Control 5.10 - Acceptable Use of Information and Associated Assets: The policy establishes rules governing appropriate use of AI technologies and organisational assets.
- Control 5.12 - Classification of Information: The policy prohibits entry of sensitive or classified information into unapproved AI systems.
- Control 5.23 - Information Security for Use of Cloud Services: The policy addresses risks associated with third-party AI platforms and cloud-based services.

8. Policy Sanctions

Any violation of this policy will be investigated by the Information Security function in collaboration with Human Resources and business leadership. Corrective actions will be proportionate to the severity of the violation and may include disciplinary measures, termination of employment or contracts, and legal action where applicable.

POLICY 6: INCIDENT MANAGEMENT POLICY

Policy ID	SCT-IMP-006
Version	1.0
Effective Date	18 February 2026
Author (Role)	Information Security Manager
Policy Owner	Chief Information Security Officer (CISO)
Reviewer	Legal Counsel, IT Operations Manager, HR Director
Approver	Chief Operating Officer (COO)
Current Review Date	19 February 2026
Next Review Date	19 February 2027
Domain	ISO 27002:2022 - 5 Organizational Controls
Sub-domain	5.24, 5.25, 5.26, 5.27, 5.28, 6.3 & 6.4

1. Purpose

To establish a standardized approach for managing information security incidents to protect Securyth Consulting information assets, ensure business continuity, and maintain compliance with legal and regulatory obligations.

2. Scope

All employees, third parties with access to Securyth Consulting, all information assets, and all locations (San Francisco HQ; Austin, London, Singapore offices).

3. Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer	Policy Owner; overall incident coordination; escalation to senior management; final decision-making authority.
Information Security Manager	Policy Author; maintain procedures; coordinate investigations; classify incidents; document lessons learned.
Security Engineer	Technical lead for investigation; containment and remediation; capture forensic images.
Security Analyst	24/7 monitoring; initial triage; escalation.
IT Help Desk Manager	First point of contact for incident reporting; initial triage and logging.
IT Operations Manager	Oversee system recovery; coordinate with infrastructure teams.
Legal Counsel	Advise on regulatory reporting; preserve evidence; chain of custody.

HR Director	Coordinate personnel matters; manage disciplinary actions.
Communications Director	Manage internal and external communications.
All Employees	Report suspected incidents immediately; cooperate during investigations.

4. Incident Classification

Severity	Definition	Response Time
Critical (L1)	Severe business impact; data breach; regulatory implications. Report to: CIO, Board	Within 15 minutes
High (L2)	Significant business impact; potential escalation. Report to: CISO, IT Ops Manager	Within 1 hour
Medium (L3)	Moderate impact; contained incident. Report to: InfoSec Manager	Within 4 hours
Low (L4)	Minimal impact; no business disruption. Report to: IT Help Desk Manager	Within 24 hours

5. Incident Response Lifecycle

5.1 Detection and Reporting

- Report via: incident@Securythconsulting.com | +1 (415) 555-0199 | helpdesk.Securythconsulting.com | #security-incidents (Slack)
- 24/7 monitoring by Security Analyst

5.2 Assessment and Triage

- IT Help Desk Manager or Security Analyst assesses report
- Information Security Manager classifies severity
- Security Engineer identifies initial containment

5.3 Containment

- Short-term containment: Security Engineer
- Long-term containment: Security Engineer with IT Support
- Forensic images: Security Engineer; Chain of custody: Legal Counsel

5.4 Investigation and Analysis

- Root cause analysis: Security Engineer and Information Security Manager
- Evidence preservation: Legal Counsel
- Impact assessment: Information Security Manager

5.5 Remediation and Recovery

- Threat removal: Security Engineer
- System restoration: IT Support under IT Operations Manager
- Patch vulnerabilities: IT Operations team
- Enhanced monitoring: Security Analyst

5.6 Post-Incident Review

- Lessons learned within 10 days: Information Security Manager
- Update procedures: CISO
- Final report to: CIO
- Training updates: HR Director

6. Communication

Stakeholder	Timing	Responsible
Senior Management	Immediate (L1); 24h (L2)	CISO
Regulatory Authorities	Per law (GDPR: 72h)	Legal Counsel
Affected Customers	As determined	Communications Director
All Employees	As appropriate	HR Director
Board of Directors	Quarterly/material incidents	CIO

7. Training and Awareness

- Annual security awareness training: HR Director
- Quarterly tabletop exercises: Information Security Manager
- Annual incident response drill: CISO
- New hire orientation: HR Director

8. Compliance and Enforcement

Violations may result in disciplinary action up to termination (HR Director), legal action (Legal Counsel), or contract termination for third parties.

POLICY 7: CLEAR DESK AND CLEAR SCREEN POLICY

Issue Date	18 February 2026
Next Review Date	18 February 2027
Author	Information Security Manager
Policy Owner	Chief Information Security Officer
Reviewer	Information Security Manager
Approver	Chief Information Security Officer
Classification	Internal - Confidential
Approval Method	Signed Approval Record
ISO/IEC 27002:2022 Domain	Physical Controls - Domain 7
Sub-domain	7.7 Clear Desk and Clear Screen
Control Type	Preventive

1. Purpose

To ensure that personal, confidential or otherwise sensitive information (in digital and physical formats) and information assets (for example, computers and mobile devices, notebooks etc.) that hold or provide direct access to confidential organizational information, are not left unprotected at desks or in personal workspaces or public settings when they are not in use.

2. Scope

Everyone working at or for Securyth has a responsibility to use information securely, and to maintain the integrity of, and appropriate levels of confidentiality for Securyth Consulting records and information. The policy is binding on all those who use or have access to confidential Securyth Consulting information, such as staff, contractors and consultants, whether accessing this information from on or off premises.

3. Policy Statement

This policy aligns with ISO 27002:2022 Domain 7 Physical Controls, specifically Control 7.7: Clear Desk and Clear Screen, which requires organizations to ensure that sensitive information is not exposed when unattended and that unauthorized individuals cannot view confidential data. The policy satisfies these requirements by mandating screen locking to prevent unauthorized viewing, enforcing desk clearance rules to protect sensitive information, requiring visitor escorts and secure document storage to reduce insider threat risks, and ensuring that physical workspaces remain secure using lockable cabinets.

4. Clear Desk Policy

i. Ensure you have taken reasonable measures to prevent unauthorised access to confidential information. Lock away documents containing restricted or confidential information when the records are not in use and when the office/workspace is unoccupied or the workstation is left unattended for an extended period.

- ii. If you are away from your desk for a short period of time, ensure any hard copy records containing confidential information are not left in view and that devices/screens are locked.
- iii. Avoid printing or duplicating documents unnecessarily. Do not leave printing on or by copiers for others to find; wherever possible, remain at the printer while your print job is in progress. Keep your ID card safe and report any loss of a card to Security without delay.
- iv. Store confidential records and files securely and out of sight. Pedestal and tambour units, drawers, filing cabinets and/or shared cupboards and storerooms should be locked when left unattended.
- v. Keep desks and workspaces free of clutter. Actively manage records and data at all stages of the information life cycle, using appropriate storage solutions to ensure the safekeeping, accessibility, and retention of records for as long as required.

5. Clear Screen Policy

- i. There is a risk that information could be viewed by unauthorised users if left on an unlocked and unattended monitor or display screen. Lock your computer screen whenever it is left unattended. For Windows machines, use Ctrl+Alt+Del and Enter or the Windows key and L. For Macs, use Control+Shift+Power. IT Services provide further guidance on enabling screen locks.
- ii. Position/protect screens and devices to prevent members of the public, or people passing by who lack the necessary authority, from being able to see any confidential information that may be displayed.

6. Monitoring and Compliance

The organization monitors compliance with its security requirements through structured oversight activities conducted at defined intervals. Clear desk adherence is verified through monthly physical inspections by the Security Manager using checklists, while screen auto-lock settings are validated quarterly through endpoint audits performed by IT Operations with supporting audit logs. Visitor escort compliance is reviewed monthly by Facilities via visitor logbooks.

POLICY 8: REMOTE WORK POLICY

Issue Date	21 February 2026
Next Review Date	21 February 2027
Author	Head HR
Policy Owner	Chief Financial Officer
Reviewer	Information Technology Officer
Approver	Chief Financial Officer
Classification	Internal - Confidential
Approval Method	Signed Approval Record

1. Purpose

The objective of the Remote Work Policy is to provide a framework for employees working outside the traditional physical office space. Remote work offers employees the opportunity to work from anywhere with internet, allowing flexibility and reduced commute hassle.

2. Scope

Remote work is a flexible arrangement in which an employee is scheduled to perform work at an alternative worksite on a regular and recurring basis. All eligible employees may work remotely full-time.

3. Eligibility

- Full-time and contract staff are eligible for Remote Work. Only employees that are in roles that require primarily digital communication, phone, video, or data entry are eligible to work from home. All employees who are not listed as eligible employees are ineligible for Remote Work.
- Must have reliable internet access.
- Must be able to operate with minimal supervision.

4. Communication Practices

Employees need to have a secure Wi-Fi connection including a strong password. The password needs to be complicated and difficult to guess. In the event of an incident, the breach must be reported immediately to IT.

5. Data

Business data can only be stored and transmitted on company-approved tools and file sharing methods, including secure devices or cloud storage.

6. Devices

Only company-provided laptops and smartphones can be used for remote work. All devices must be encrypted and updated with antivirus software. All personal systems and devices need to be regularly updated as well.

All employees must use the corporate VPN when logging into company servers. Multi-Factor Authentication needs to be applied to all devices and services. Laptops and mobile device screens should be locked when not in use and should not be left unattended. Keep working area free of third-party devices.

7. Cybersecurity Training

Mandatory online information safety training is required for all remote employees. Employees should build awareness of suspicious email and phishing attacks. All data breaches must be recorded for compliance recording.

POLICY 9: MOBILE DEVICE POLICY

Policy Title	Mobile Device Policy
Policy Version	1.0
Policy Classification	Internal
Effective Date	21 February 2026
Next Review Date	21 February 2027
Author	Information Security Manager
Policy Owner	Chief Information Security Officer (CISO)
Reviewer	IT Security Engineer
Approver	Chief Information Officer (CIO)
Approval Date	20 February 2026
Approval Method	Email Approval
Status	Approved

1. Purpose

This policy defines the security requirements for the use of mobile devices to protect organisational information from unauthorized access, loss, or compromise. It ensures secure mobile access while supporting operational efficiency.

2. Scope

This policy applies to:

- All employees, contractors, interns, and third parties
- All mobile devices used to access organisational information

3. Policy Statement

All mobile devices that store, process, or access organisational information shall be configured, used and managed in accordance with this policy to reduce the risk of data loss, unauthorized access and security incidents.

4. Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer (CISO)	Owns and approves the policy; ensures alignment with security objectives.
Information Security Manager	Develops and maintains the policy; monitors compliance.
IT Security Engineer	Implements technical controls; responds to mobile security incidents.

Employees and Users	Comply with policy requirements; report incidents promptly.
---------------------	---

5. Policy Requirements

- All mobile devices used for work must be registered with the IT department.
- BYOD devices require formal approval before accessing organisational systems.
- Devices must be protected using strong passwords, PINs, or biometric authentication.
- Automatic screen lock must activate after 5 minutes of inactivity.
- Full-disk encryption must be enabled on all mobile devices.
- Organisational data transmitted over public or untrusted networks must be encrypted.
- Confidential information shall not be stored locally unless explicitly approved.
- Only organisation-approved applications and cloud services may be used.
- Lost or stolen devices must be reported within 24 hours.
- IT Security shall initiate containment actions, including access suspension and data wipe where necessary.

6. Incident Management

Mobile device-related security incidents shall be managed in line with the organisation's Incident Management Policy, including investigation, containment, and reporting.

7. Compliance and Enforcement

Non-compliance with this policy may result in:

- Disciplinary action
- Suspension or revocation of system access
- Legal or regulatory consequences where applicable

8. Acceptance

All users must acknowledge and comply with this policy as a condition for accessing organisational systems.

9. Review and Communication

- This policy shall be reviewed annually or upon significant changes.
- The policy shall be communicated to all employees through email, security awareness training, and policy management platform.

POLICY 10: CORPORATE TRAVEL SECURITY POLICY

Issue Date	21 February 2026
Next Review Date	21 February 2027
Author	Head HR
Policy Owner	Chief Financial Officer
Reviewer	Information Technology Officer
Approver	Chief Financial Officer
Classification	Internal - Confidential
Approval Method	Signed Approval Record

1. Introduction

This Corporate Travel Security Policy of Securyth is set up to prioritize the safety and well-being of employees and their data when they travel for business purposes. This policy outlines guidelines and procedures to minimize risks associated with business travel and ensure employees have access to support in the event of an incident.

2. Purpose

The design of the Corporate Travel Security Policy is to provide a framework to minimize exposure to threats while providing a smooth travel experience. This covers all employees and executives. It does not cover contractors or third-party vendors. Travel includes all local and international trips.

3. Travel Planning and Approval

3.1 Travel Authorization

All business travel must be approved in advance by the employee's supervisor or department head. A travel request ticket must include all essential trip details including the purpose, destination, dates, and expected expenses.

3.2 Travel Itinerary and Emergency Contacts

Travelers are required to provide business contact information and submit their full travel itinerary to HR before the trip.

4. Safety Precautions

The supervisor and the employee must review the pre-travel assessments involving destination briefings, health checks and threat level reviews. High risk locations will require approval from senior management. The traveler also needs to review the incident response procedures detailing the plan for accidents, illness, missing persons and evacuations.

5. Employee Training

Before travel, all employees are required to undergo security awareness training. They will learn basic security tips, cultural awareness, health precautions, and emergency protocol. It will cover

online security, Wi-Fi networks, phishing scams, and compliance with GDPR and PCI DSS alignment.

6. Transportation and Accommodation

All travel arrangements must be made through the organization's designated travel management system. Quality transportation and accommodation should be provided to ensure comfort and safety of the employees. Any expenses incurred should be in line with the interest of the company.

7. Travel Safety

In all foreign travels, the organization provides travel insurance coverage for all staff on official business. When traveling, the employee must never display their nametag when outside of the corporate environment.

8. Technology

When traveling internationally, the employee must always keep their company-provided phone with them and the GPS turned on. The device must be updated on a regular basis, backed with a strong password and multifactor authentication.

All devices containing sensitive data, such as employee information, financial details, and travel schedules must be stored on a company-approved device. The device utilizes a VPN, firewalls, and has an End Point Detection service installed. The device must also use automated fraud detection software.

9. Compliance

All employees are expected to comply with this Travel Policy. Failure to comply with this policy may result in non-reimbursement of expenses and/or disciplinary action.

Recommendations

The following recommendations provide practical and governance-aligned measures to ensure policies are not only documented but actively followed and enforced:

- i. Policies should be communicated clearly through multiple channels such as onboarding sessions, training workshops, internal portals, and official announcements. Communication must explain why the policy exists, what employees must do and consequences of non-compliance.
- ii. Policies should be embedded into operational processes, systems, and workflows. Examples include automatic screen-lock enforcement, access approval workflows and travel authorization procedures.
- iii. Policies should be reviewed periodically and after major events such as regulatory changes and security incidents
- iv. Technology solutions such as monitoring systems, identity management platforms, and compliance dashboards help enforce policies consistently and reduce human error.
- v. Organizations should track compliance through measurable indicators such as audit findings and incident reports

Policy Compliance Framework Implementation

The compliance framework is a tool we use to track how well the firm follows its security rules. It moves the policies from documents into actual daily practice. This framework lists every policy along with a specific schedule for checking them. It identifies the staff members responsible for performing the checks and the leaders who must review the results.

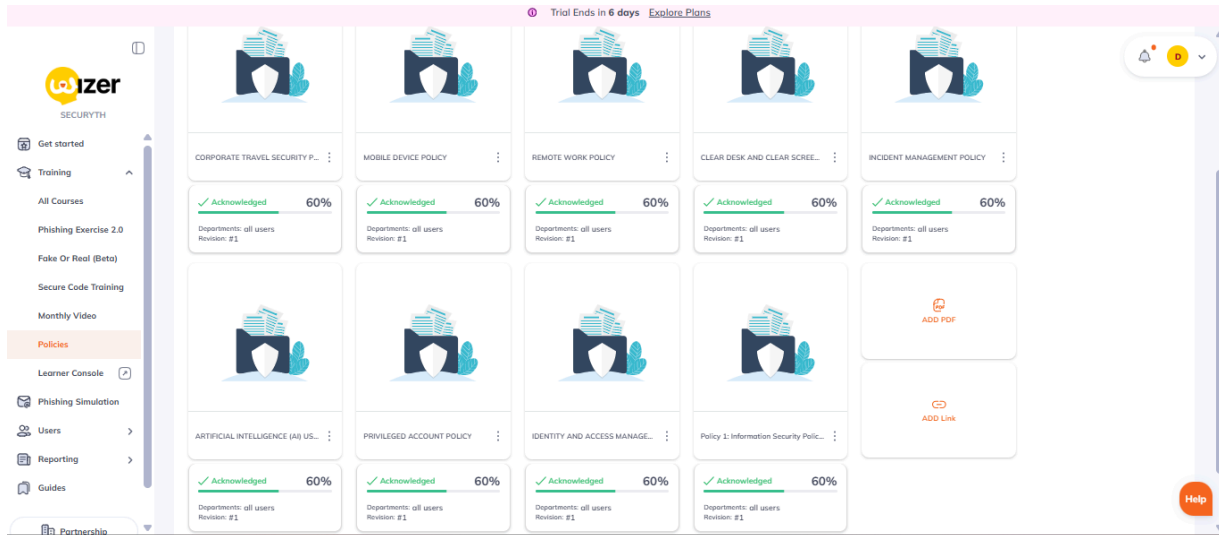
By using this tracker, we can collect proof that security activities are happening as planned. This helps the firm stay ready for audits and allows us to find and fix security gaps quickly. The framework ensures that every policy stays current and effective as the business grows.

Policy Compliance Framework																		
Securyth Consulting GRC Policy Report Version 1.0 February 2026																		
Policy Name	Policy Statement / Guideline	Frequency of Review	Reviewer	Implementer	J	F	M	A	M	J	J	A	S	O	N	D	Comments / Evidence	Status
Privileged Account Policy	Review of Privileged Accounts	Annually	Information Security Manager	IAM Specialist													Approved	Approved
Information Security Policy	Information Security Framework	Annually	Risk & Compliance Director	Information Security Manager													Approved	Approved
Information Classification Policy	Information Classification Framework	Annually	Information Security Manager	Chief Information Security Officer (CISO)													Approved	Approved
Identity Management & Access Control Policy	IAM Policy	Annually	IAM Specialist	Chief Information Officer													Approved	Approved
AI Usage & Governance Policy	Use of AI	Annually	Information Security Manager	Chief Information Security Officer (CISO)													Approved	Approved
Incident Management Policy	Incident Management Response and SLAs	Quarterly	Legal Counsel, IT Operations Manager, HR Director	Chief Operating Officer (COO)													Approved	Approved
Clear Desk and Clear Screen Policy	Clear Desk and Clear Screen Policy	Annually	Information Security Manager	Chief Information Security Officer													Approved	Approved
Remote Work Policy	Remote Work Rules	Annually	Information Technology Officer	Chief Financial Officer													Approved	Approved
Mobile Device Policy	Use of Mobile Devices	Annually	IT Security Engineer	Chief Information Officer (CIO)													Approved	Approved
Corporate Travel Security Policy	Travel Requirements and Permissions	Annually	Information Technology Officer	Chief Financial Officer													Approved	Approved

Policy Communication through Wizer

We used the Wizer platform to share these new policies with the entire organization. All ten policies were uploaded to this central portal so that every employee and contractor can access them at any time. This creates a single reliable source for all our security requirements.

The platform allows us to monitor which staff members have opened and read the policies. This tracking feature provides the firm with a clear record of who has been informed of their duties. Using a digital portal ensures that the most recent versions of our rules are always available, which helps reduce confusion and improves the overall security culture at the firm.



Acknowledge policy

By clicking Acknowledge, you submit that you have read
and agree to the
**"ARTIFICIAL INTELLIGENCE (AI) USAGE AND
GOVERNANCE POLICY"**

Acknowledge ✓

Conclusion

Successful policy implementation requires more than written documents - it depends on leadership commitment, clear communication, training, monitoring, and continuous improvement. By integrating policies into operations, measuring compliance, and fostering a culture of accountability, organizations can ensure that policies effectively protect assets, maintain compliance, and support strategic objectives.